LAB 5 — STATIC CODE ANALYSIS

Retail Point of Sale & Discount Tracker

Student	Dhanush Gowda A S
SRN	PES1UG25CS812
Repository	SE-Labs-PES1UG25CS812
Folder	LAB5_PES1UG25CS812

1. Objective

Analyze the supplied Retail POS starter program using Pylint, Bandit and Flake8; document defects, remediate the implementation, and compare static-analysis results before and after the changes.

2. Tools

Pylint — Python code-quality diagnostics.
Bandit — security-focused static analysis.
Flake8 — style and lint checks.
unittest — regression tests for checkout, validation, promotions, inventory and receipt logging.

3. Before-and-after results

Analyzer	Before	After
Pylint	5.78 / 10	10.00 / 10
Bandit	3 findings (2 Low, 1 Medium)	No findings reported
Flake8	Multiple violations	No violations reported
Regression tests	Baseline defects present	Passed in GitHub Actions

4. Issues identified and fixes

Unsafe eval(): Replaced arbitrary expression evaluation with allow-listed promo codes.

Mutable default argument: Replaced shared receipts=[] with None and per-call handling.

Broad exception handling: Added explicit validation and meaningful exceptions.

Invalid cart inputs: Rejects unknown products, invalid quantities and invalid tax rates.

Stock update defect: Implemented validated inventory quantity updates.

Unmanaged file handling: Uses a context manager and UTF-8 encoding.

Style and maintainability: Applied snake_case naming, documentation and consistent formatting.

5. Validation and reproducibility

The repository's GitHub Actions run completed successfully: dependencies were installed, regression tests passed, and the six before/after analyzer reports were generated and committed. The corrected source achieved a Pylint score of 10.00/10, with no Bandit findings and no Flake8 violations.

To reproduce locally, run `python -m pip install -r requirements.txt`, `python -m unittest discover -s tests -v`, and `python run_analysis.py`.

6. Deliverables

The folder contains the original baseline source, corrected source, issue register, reflection, README, analysis runner, requirements, regression tests, six analyzer output files and this PDF report.

This is the project report, not a replacement for any separate official lab handout or template issued by the instructor.